Практическая работа № 4. Парольная защита

Часть 1.

Цель работы: изучение принципов организации парольной защиты программ, ознакомление с видами паролей, реализация парольной защиты.

Парольная идентификация

Стандартность архитектурных принципов построения, оборудования и программного обеспечения персональных компьютеров, мобильность программного обеспечения определяют сравнительно легкий доступ к информации, находящейся в персональном компьютере. Несанкционированный доступ к информации персонального компьютера - незапланированное ознакомление, обработка, копирование, применение различных вирусов, модификация или уничтожение информации в нарушение правил доступа.

Под защитой информации понимают создание организованной совокупности средств, методов и мероприятий, предназначенных для предупреждения искажения, уничтожения или несанкционированного использования защищаемой информации. К ним относятся аппаратные и программные средства, криптографическое закрытие информации, физические меры, организационные мероприятия и законодательные меры. Один из методов защиты - парольная идентификация, ограничивающая доступ несанкционированного пользователя.

Включение защиты в программу связано с разработкой программ с запросом информации, т.е. требующих для своей работы ввода дополнительной информации, такой как пароли или номера ключей. Однако такая проверка доступа к программам или системам не должна существенно сказываться на быстродействии программы или требовать от пользователя сложных дополнительных действий.

Пароль - это код, используемый для получения доступа к системам или файлам, оснащенным парольной защитой. Пароли обеспечивают сохранение целостности программного обеспечения в составе вычислительной системы, но для поддержания паролей требуется высокая дисциплинированность. При первой регистрации пользователя администратор определяет круг полномочий для получения и изменения информации или выполнения определенных управляющих действий в системе, руководствуясь его профессиональными обязанностями и должностными инструкциями. Затем пользователю прелагается ввести свой пароль согласно правилам, принятым в данной системе. Метод паролей требует, чтобы вводимый пользователем пароль (строка символов) сравнивался с

тем, который хранится в вычислительной системе для данного пользователя. Если пароль верен, система должна вывести на экран терминала дату и время последнего входа в систему этого пользователя. Затем пользователю предоставляется возможность пользоваться всей информацией, доступ к которой ему разрешен (пароли можно также использовать независимо от пользователя для защиты файлов, записей, полей данных внутри записей и т.д.). Процедура установления подлинности пользователей с помощью пароля приведена на рисунке **4**.1.

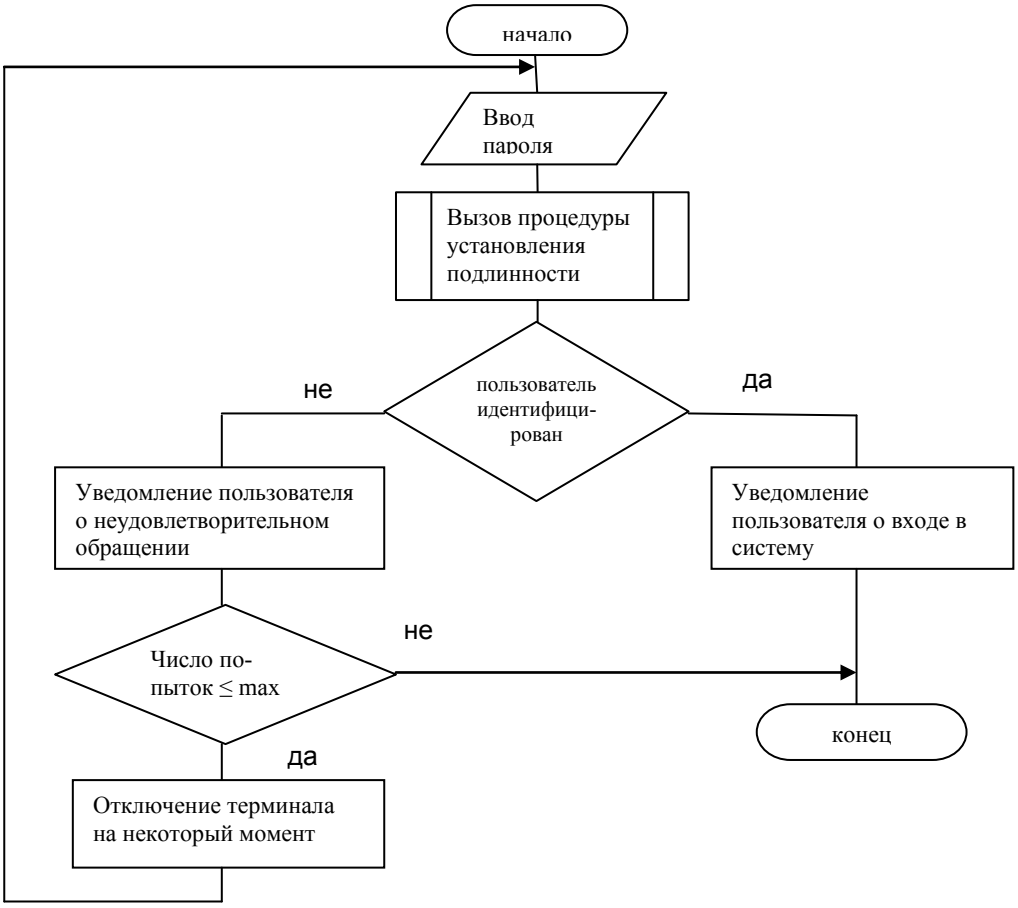

Рисунок 7.1 - Схема установления подлинности пользователя.

Парольная защита является достаточно эффективной, если:
- сохранять пароль в тайне;
- просматривать систему для поиска резидентных программ или троянских коней, предназначенных для перехвата паролей; установить защиты в системе от таких программ;
- установить требования к минимальной длине и множеству символов в паролях;
- при наличии средств использовать интеллектуальные карты, опознавательные знаки, биометрические устройства управления доступом;
- осуществлять периодическое изменение паролей и контроль их сроков действия.

Система не должна отображать вводимые пользователем пароли, либо на месте ввода выводить последовательность случайных символов. Не следует хранить пароли в открытом в виде или на носителе. Немедленно после ввода пароля производить шифрование пароля и очистку памяти, содержащую открытый текст пароля. Для предотвращения угадывания пароля рекомендуется использовать пароли, генерируемые компьютером, а также

производить блокировку после определенного количества попыток ввода неправильного пароля.

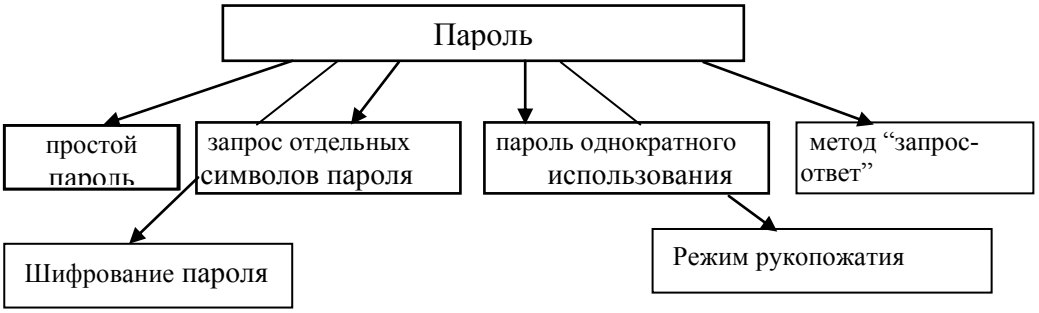

Рисунок **4**.2 - Виды паролей

Простой пароль

Простой пароль - вводимая пользователем с клавиатуры строка символов. В схеме с простым паролем пользователю разрешается самому выбирать пароль таким образом, чтобы его было легко запомнить. Иногда в ряду символов пароля и в конце его оставляют пробелы. Отличие действительного пароля от кажущегося (без пробелов) повышает защищенность системы.

Подбор пароля путем простого перебора комбинаций предполагает перебор всех возможных сочетаний символов в пароле. Время, необходимое для разгадывания пароля методом простого перебора, является геометрической прогрессией от длины пароля, но есть различные кривые, зависящие от размера алфавита, на основе которого был создан пароль и от размера набора символов, по отношению к которым рассматриваются различные пароли.

Согласно формуле Андерсена:

$$4{,}32 \cdot 10^4 \cdot {}^{R \cdot M}/_{E \cdot P} \leq A^S \qquad (\mathbf{4}.1)$$

где *R* - скорость передачи в линии связи (симв./с);

E - число символов в каждом передаваемом сообщении при попытке получить доступ;

S - длина пароля;

A - число символов в алфавите, из которого составлен пароль;

P - вероятность правильного отгадывания пароля.

Наибольшее влияние на вероятность P раскрытия пароля оказывает величина S. Увеличение пароля на один символ значительно увеличивает время для раскрытия этого пароля. Поэтому применение очень длинных паролей может быть обосновано. Борьба с перебором комбинаций заключается в использовании программного обеспечения, ограничивающего минимальную длину пароля и использовании более обширного алфавита (256 символов).

Выборка символов

Использование в качестве пароля отдельных символов условного слова (например, 1 и 5 буква) предотвращает ситуацию, когда целое слово может быть случайно услышано. Запрашиваемые символы пароля изменяются при каждой новой попытке доступа. Позиции запрашиваемых символов можно получить с помощью некоторой процедуры преобразования, привязанной к показаниям часов ЭВМ или выработать генератором псевдослучайных чисел. Однако пароль следует изменять достаточно часто, поскольку он может быть составлен из отдельных символов.

Пароль однократного использования

В схеме однократного использования пароля пользователю выдается список из N паролей. Такие же N паролей хранятся в ЭВМ (в зашифрованном виде). Данная схема обеспечивает большую степень безопасности, но она является и более сложной. После

использования пароля пользователь вычеркивает его из списка. При дальнейшей работе система на этот пароль реагировать не будет, поскольку ожидает следующий по списку пароль.

Пароли однократного использования могут применяться также для установления подлинности подтверждения об отключении ЭВМ от обслуживания пользователя и подтверждения подлинности требования пользователя об отключении от ЭВМ. Всякий раз, когда получено требование пользователя об окончании работы, ЭВМ немедленно передает ему свой пароль однократного использования и прерывает связь. Если пользователь отключается и не получает истинного пароля от ЭВМ, ему следует принять меры предосторожности.

Недостатки паролей однократного использования:

- пользователь должен помнить весь список паролей и следить за текущим паролем;
- в случае ошибки в процессе передачи пользователь не знает, следует ли ему передать тот же пароль или послать следующий;
- если пароли определены путем использования линейной последовательности псевдослучайных чисел, то первоначальная последовательность может быть восстановлена на основании нескольких перехваченных паролей.

Метод “запрос-ответ”

В методе “запрос-ответ” набор ответов на m стандартных и n ориентированных на пользователя вопросов хранится в ЭВМ и управляется операционной системой. Когда пользователь делает попытку включиться в работу, операционная система случайным образом выбирает и задает ему некоторые (или все) из этих вопросов. Пользователь должен дать правильный ответ на все вопросы, чтобы получить разрешение на доступ к системе. Иногда пользователям задается большое количество стандартных вопросов и от них требуются ответы на те, которые они выберут.

Шифрование паролей

Шифрование пароля повышает безопасность системы. Этот метод предполагает, что пароль, вводимый при входе в систему, шифруется и сравнивается с зашифрованным паролем, хранящимся в базе данных. Для шифрования пароля можно использовать простой метод обратимого шифрования или более сложный метод “необратимой беспорядочной сборки”, когда несколько паролей в явной форме преобразуются в одинаковый зашифрованный пароль. В этом случае не существует никакой схемы для возвращения к оригиналу пароля. Система просто шифрует каждый пароль пользователя во время процесса регистрации и сверяет его с зашифрованным паролем, хранящимся в собственном файле пользователя.

Пример этого метода - полиномиальное необратимое представление:

$$f(x) = (x^n + a_1 \cdot x^{n-1} + \cdots + a_{n-1} \cdot x + a_0) mod\ P \qquad (7.2)$$

где P- большое, a_i и n - целые числа; x -пароль в явной форме; $f(x)$ - зашифрованный пароль.

Режим “рукопожатия”

Операционная система может потребовать, чтобы пользователь установил свою подлинность с помощью корректной обработки алгоритмов, которую называют режимом “рукопожатия” и она может быть выполнена как между двумя ЭВМ, так и между пользователем и ЭВМ.

ЭВМ для установления подлинности могла дать пользователю число, выбранное случайным образом, а затем запросить от него ответ. Для подготовки ответа пользователь “u” применяет собственное заранее подготовленное преобразование t_u. Информацией, на основе которого принимается решение, здесь является не пароль, а преобразование t_u. ЭВМ посылает значение x, а пользователь отвечает значением $t_u(x)$. Даже в случае знания значений x и $t_u(x)$

угадать функцию преобразования невозможно. Функция преобразования может быть различна для каждого пользователя.

Порядок выполнения работы

1. Изучить существующие методы парольной защиты

2. Выбрать метод парольной защиты в соответствии с заданным вариантом из таблицы **4**.1.

3.Разработать алгоритм и программную реализацию выбранного метода парольной защиты с использованием демонстрационных возможностей выбранного языка программирования.

4. Оформить отчет.

Таблица **4**.1 – Виды парольной защиты

№ варианта	Вид парольной защиты
1	Выборка символов
2	Пароль однократного использования
3	Шифрование паролей
4	Метод “запрос-ответ”
5	Режим “рукопожатия”
6	Выборка символов
7	Простой пароль
8	Шифрование паролей
9	Метод “запрос-ответ”
10	Режим “рукопожатия”
11	Выборка символов
12	Простой пароль
13	Пароль однократного использования
14	Шифрование паролей
15	Выборка символов
16	Метод “запрос-ответ”
17	Простой пароль
18	Режим “рукопожатия”
19	Выборка символов

Часть № 2

Количественная оценка стойкости парольной защиты

Цель работы: реализация простейшего генератора паролей, обладающего требуемой стойкостью к взлому.

Теоретические сведения

Подсистемы идентификации и аутентификации пользователя играют важную роль в системах защиты информации.

Стойкость подсистемы идентификации и аутентификации пользователя в системе защиты информации (СЗИ) во многом определяет устойчивость к взлому самой СЗИ. Данная стойкость определяется гарантией того, что злоумышленник не сможет пройти аутентификацию, присвоив чужой идентификатор или украв его.

Парольные системы идентификации/аутентификации являются одними из основных и наиболее распространенных в СЗИ методами пользовательской аутентификации. В данном случае информацией, аутентифицирующей пользователя, является некоторый секретный пароль, известный только легальному пользователю.

Парольная аутентификация пользователя, как правило, передний край обороны СЗИ. В связи с этим модуль аутентификации по паролю наиболее часто подвергается атакам со стороны злоумышленника. Цель последнего в данном случае – подобрать аутентифицирующую информацию (пароль) легального пользователя.

Методы парольной аутентификации пользователя наиболее просты и при несоблюдении определенных требований к выбору пароля являются достаточно уязвимыми.

Основными минимальными требованиями к выбору пароля и к подсистеме парольной аутентификации пользователя являются следующие.

К паролю:

1) минимальная длина пароля должна быть не менее 6 символов;

2) пароль должен состоять из различных групп символов (малые и большие латинские буквы, цифры, специальные символы ‘(’, ‘)’, ‘#’ и т.д.);

3) в качестве пароля не должны использоваться реальные слова, имена, фамилии и т.д.

К подсистеме парольной аутентификации:

1) администратор СЗИ должен устанавливать максимальный срок действия пароля, после чего, пароль следует сменить;

2) в подсистеме парольной аутентификации необходимо установить ограничение числа попыток ввода пароля (как правило, не более трёх);

3) в подсистеме парольной аутентификации требуется установить временную задержку в случае ввода неправильного пароля.

Как правило, для генерирования паролей в СЗИ, удовлетворяющих перечисленным требованиям к паролям, используются программы – автоматические генераторы паролей пользователей.

При выполнении перечисленных требований к паролям и к подсистеме парольной аутентификации единственно возможным методом взлома данной подсистемы злоумышленником является прямой перебор паролей (brute forcing). В данном случае, оценка стойкости парольной защиты осуществляется следующим образом.

Количественная оценка стойкости парольной защиты

Пусть A – мощность алфавита паролей (количество символов, которые могут быть использованы при составлении пароля: если пароль состоит только из малых английских букв, то $A = 26$), L – длина пароля, $S = A^L$ – число всевозможных паролей длины L, которые можно составить из символов алфавита A, V – скорость перебора паролей злоумышленником, T – максимальный срок действия пароля.

Тогда, вероятность P подбора пароля злоумышленником в течение срока его действия V определяется по следующей формуле:

$P = (V \cdot T) / S = (V \cdot T) / A^L$.

Эту формулу можно использовать в обратную сторону для решения следующей задачи.

Задача. Определить минимальные мощность алфавита паролей A и длину паролей L, обеспечивающих вероятность подбора пароля злоумышленником не более заданной P, при скорости подбора паролей V, максимальном сроке действия пароля T.

Данная задача имеет неоднозначное решение. При исходных данных V, T, P однозначно можно определить лишь нижнюю границу S^* числа всевозможных паролей. Целочисленное значение нижней границы вычисляется по формуле

$$S^* = [V \cdot P / T], \qquad (1)$$

где [] – целая часть числа, взятая с округлением вверх.

После определения нижней границы S^* необходимо выбрать такие A и L для формирования $S = A^L$, чтобы выполнялось следующее неравенство:

$$S^* \leq S = A^L. \qquad (2)$$

При выборе S, удовлетворяющего неравенству (2), вероятность подбора пароля злоумышленника (при заданных V и T) будет меньше, чем заданная P.

Следует отметить, что при осуществлении вычислений по формулам (1) и (2), величины должны быть приведены к одним размерностям.

Пример. Исходные данные: $P = 10^{-6}$, $T = 7$ дней = 1 неделя, $V = 10$ (паролей / минуту) = $10 \cdot 60 \cdot 24 \cdot 7 = 100800$ паролей в неделю. Тогда, $S^* = [(10800 \cdot 1) / 10^{-6}] = 108 \cdot 10^8$.

Условию $S^* \leq A^L$ удовлетворяют, например, такие комбинации A и L, как $A = 26$, $L = 8$ (пароль состоит из восьми малых символов английского алфавита),

A = 36, L = 6 (пароль состоит из шести символов, среди которых могут быть малые латинские буквы и произвольные цифры).

Задание на лабораторную работу

1. В табл. 3 найти для указанного варианта значения характеристик P, V, T.
2. Вычислить по формуле (1) нижнюю границу S^* для заданных P, V, T.
3. Выбрать некоторый алфавит с мощностью A и получить минимальную длину пароля L, при котором выполняется условие (2).
4. Реализовать программу для генерации паролей пользователей. Программа должна формировать случайную последовательность символов длины L, при этом должен использоваться алфавит из A символов.
5. Оформить отчет по лабораторной работе.

Коды символов:

1. Коды английских символов : «A» = 65, …, «Z» = 90, «a» = 97,…, «z» = 122.
2. Коды цифр : «0» = 48, «9» = 57.
3. «!» = 33, «“» = 34, «#» = 35, «$» = 36, «%» = 37, «&» = 38, «‘» = 39.
4. Коды русских символов : «А» – 128, … «Я» – 159, «а» – 160,…, «п» – 175, «р» – 224,…, «я» – 239.

Таблица 3. Варианты заданий

Вариант	P	V	T
1	10^{-4}	15 паролей/мин	2 недели
2	10^{-5}	3 паролей/мин	10 дней
3	10^{-6}	10 паролей/мин	5 дней
4	10^{-7}	11 паролей/мин	6 дней
5	10^{-4}	100 паролей/день	12 дней
6	10^{-5}	10 паролей/день	1 месяц
7	10^{-6}	20 паролей/мин	3 недели
8	10^{-7}	15 паролей/мин	20 дней
9	10^{-4}	3 паролей/мин	15 дней
10	10^{-5}	10 паролей/мин	1 неделя
11	10^{-6}	11 паролей/мин	2 недели
12	10^{-7}	100 паролей/день	10 дней
13	10^{-4}	10 паролей/день	5 дней
14	10^{-5}	20 паролей/мин	6 дней
15	10^{-6}	15 паролей/мин	12 дней
16	10^{-7}	3 паролей/мин	1 месяц
17	10^{-4}	10 паролей/мин	3 недели
18	10^{-5}	11 паролей/мин	20 дней
19	10^{-6}	100 паролей/день	15 дней
20	10^{-7}	10 паролей/день	1 неделя
21	10^{-4}	20 паролей/мин	2 недели
22	10^{-5}	15 паролей/мин	10 дней
23	10^{-6}	3 паролей/мин	5 дней

Окончание табл. 3

Вариант	*P*	*V*	*T*
24	10^{-7}	10 паролей/мин	6 дней
25	10^{-4}	11 паролей/мин	12 дней
26	10^{-5}	100 паролей/день	1 месяц
27	10^{-6}	10 паролей/день	3 недели
28	10^{-7}	20 паролей/мин	20 дней
29	10^{-4}	15 паролей/мин	15 дней
30	10^{-5}	3 паролей/мин	1 неделя

Контрольные вопросы

1. Чем определяется стойкость подсистемы идентификации и аутентификации?
2. Перечислить минимальные требования к выбору пароля.
3. Перечислить минимальные требования к подсистеме парольной аутентификации.
4. Как определить вероятность подбора пароля злоумышленником в течение срока его действия?
5. Выбором каких параметров можно повлиять на уменьшение вероятности подбора пароля злоумышленником при заданной скорости подбора пароля злоумышленником и заданном сроке действия пароля?